

Degree Project Plan

Master in Cybersecurity
at University West

1 Title

Automated Compliance Mapping for IoT and AI Security Standards: An NLP-Based Approach for ETSI EN 303 645 and EN 304 223

2 Student

Name: Ashish Gurung

E-mail: asgu0012@student.hv.se

Phone: 0767573437

Start year: 2025

I.e., the year you were admitted and were a fully registered student at University West.
Please note, the first year of the program, not re-registration.

3 Course

One-year master – 15 HE credits.

4 Amendment record

Rev	Date	Purpose	Nature of change
1	20-1-22	To supervisor	Initial version -Project Idea selection
2			
3			
4			

5 Examiner

Name:

6 Supervisor

Name:

7 External supervisor at company (if applicable)

Name:

Company:

E-mail:

Phone:

8 Background

Industrial Automation is now moving away from traditional Automation to Agentic AI adoption, enabling systems to learn, adopt and make decisions autonomously and independently. The rising popularity of IoT devices creates new attack vectors, exposing user data, privacy, and safety to potential threats. To mitigate these risks, organizations must prioritize secure development and adhere to established security standards like ETSI EN 303 645 and ETSI EN 304 223. These standards are developed for professional IoT devices and AI system security respectively, which provide requirements for the development and maintenance of secure products. The main intention of these standards is to protect the confidentiality, integrity, and availability of the device.

However, achieving compliance with these standards presents challenges. Organizations developing AI-enabled IoT products face the challenge of demonstrating compliance with multiple security standards simultaneously. ETSI EN 303 645 (consumer IoT security) and ETSI EN 304 223 (AI system security) contain dozens of requirements expressed in natural language, with varying levels of specificity and overlap. While both outline security objectives, they lack concrete implementation guidance, leading to uncertainties during verification processes. Manual compliance mapping is time-consuming, error-prone, and requires deep expertise in both domains. As regulatory requirements multiply (EU Cyber Resilience Act, AI Act, sector-specific standards), the burden of compliance documentation grows exponentially.

9 Purpose

Describe why this degree project is interesting/important to carry out.
E.g., scientific/industrial interest, problem investigation/identification.

Automating compliance mapping between ETSI EN 303 645 and EN 304 223 using NLP and LLMs tackles a real challenges point for organizations navigating the increasingly complex landscape of AI and IoT security standards.

By systematically comparing automated mapping results with expert-generated mappings, the project helps identify the current limitations of AI-assisted compliance tooling and clarifies where human expertise remains indispensable. Recent advances in Natural Language Processing (NLP), particularly transformer-based models and large language models (LLMs), offer potential for automating or semi-automating compliance mapping tasks. However, the applicability of these techniques to security standards, which require precision, completeness, and interpretability, remains under-explored. This thesis investigates whether and how AI-assisted methods can accurately map security controls between ETSI EN 303 645 and EN 304 223, evaluating the feasibility, accuracy, and limitations of automated approaches for standards compliance.

The project is timely and relevant, addressing a real-world industrial problem while contributing scientifically valuable knowledge on the use of NLP and AI for security standards analysis. The outcome has the potential to support future research, improve industrial compliance practices, and inform the design of trustworthy AI-assisted compliance tools.

10 Aim(s)

The Aims of this study are as follows:

- 1) To investigate whether and how AI-assisted methods can accurately map security controls between ETSI EN 303 645 and EN 304 223, evaluating the feasibility, accuracy, and limitations of automated approaches for standards compliance.
- 2) To implement an automated gap analysis mechanism to highlight overlaps and conflicts compared to manual expert mapping in terms of: Accuracy, coverage, efficiency and interpretability
- 3) Which methods achieve the best balance of accuracy, completeness, and interpretability?

11 Investigative question(s)

The question(s) will clearly correlate to the purpose and aim(s) of the degree project and be formulated as explicit and evaluable question(s).

1. To what extent can NLP and AI techniques automatically identify semantic relationships (equivalence, overlap, subsumption, complementarity) between security

requirements in ETSI EN 303 645 and EN 304 223? What are the fundamental challenges and limitations?

2. How do different automated approaches (Rule-based NLP, Semantic (BERT-based, sentence embedding), LLM (GPT, Claude)) perform for compliance mapping tasks? Which methods achieve the best balance of accuracy, completeness, and interpretability?
3. How does automated mapping compare to manual expert mapping in terms of: Accuracy, coverage, efficiency and interpretability.

12 Theory/related research

The project will focus on systematic research on ETSI standard security requirement mapping between ETSI EN 303 645 and ETSI EN 304 223 and extends this knowledge by focusing NLP for requirements engineering, semantic similarity using transformer-based models, and AI-assisted compliance analysis.

Review of academic literature will be on:

- Detailed examination of ETSI EN 303 645 and ETSI EN 304 223 with identification of requirement structures, terminology, and security objectives
- AI & NLP for requirements engineering
- Semantic similarity and text alignment
- LLM-based document analysis
- AI-assisted compliance and security standards mapping
- Analysis of industrial white papers and regulatory guidance relevant to IoT and AI security

The degree project focuses on:

- Semantic analysis of security requirements in ETSI standards.
- Automated detection of relationships (equivalence, overlap, subsumption)
- Comparative evaluation of: Rule-based NLP Transformer-based semantic models Large Language Models
- Expert benchmarking and gap analysis
- Practical implications for industrial compliance processes

13 Investigation method

The Project will follow a Systematic Literature Review (SLR) by searching literature from reputable databases using defined search 3 queries formed by the key words related to the project aims and objectives. The SLR will follow the PRISMA framework which gives guidelines on identifying, screening and analysing relevant literature. This will involve comprehensive screening by using inclusion and exclusion matrices for literature as defined in PRISMA. • Databases: IEEE Xplore, SpringerLink, Scopus, ACM Digital Library, Web of Science • Keywords: "Automated Compliance", "ETSI EN 303 645", "ETSI EN 304 223", "Industrial Automation", "Cybersecurity", "AI system Security Standards", "", "IoT", "NLP techniques", "LLM techniques", "AI-assisted methods"

We will try to evaluate the outputs of each method using both quantitative metrics and qualitative analysis with comparative models. The necessary knowledge of the background and state-of-the-art will be obtained through extensive reading of different academic

literature related to the subject area from different databases like Springer Link, Scopus, Web of Science, ACM Digital Library and doing SLR and simulations.

14 Evaluation methods

This degree project evaluates whether its aims and research questions are met through a systematic and empirical assessment of AI-assisted compliance mapping between ETSI EN 303 645 and ETSI EN 304 223. Project implementation is determined by implementing multiple automated approach like rule-based NLP, semantic embedding models, and large language model and comparing their outputs against expert-generated mappings used as a reference baseline. The evaluation combines quantitative metrics (accuracy, precision, recall, coverage, and efficiency) with qualitative analysis (interpretability, explainability, and error analysis). Automated methods are assessed on their ability to correctly identify semantic relationships such as equivalence, overlap, subsumption, and complementarity.

Performance is benchmarked against manual expert mapping to determine where automation is effective and where human expertise remains necessary. Results are analysed using a mixed-methods approach and presented through tables, visual comparisons, and illustrative examples that directly address each research question. The findings are interpreted in relation to the project's purpose: assessing the feasibility, limitations, and trustworthiness of AI-assisted compliance mapping for security standards. Overall, the project's success is demonstrated by providing clear, evidence-based conclusions on the applicability of NLP and LLM techniques to standards compliance, offering both scientific insight and practical guidance for future AI-assisted compliance tools.

15 News value/contribution

The result will significantly contribute to the need of addressing its systematic investigation of AI-assisted compliance mapping between two complex and high-impact security standards: ETSI EN 303 645 (IoT security) and ETSI EN 304 223 (AI system security). While prior research has explored NLP and LLMs for document analysis and requirement extraction, their applicability to formal security standards where precision, traceability, and interpretability are critical that remains under-explored. The work tackles one of the hottest topics today since the world is going through an AI-driven Industrial revolution, from traditional Automation to Autonomy with little human involvement in the production line. From an industrial perspective, The project delves into the area of cutting-edge Industrial Automation faced with numerous real and growing problem for example, organizations developing AI-enabled IoT products must comply with multiple overlapping standards and regulations, including ETSI standards, the EU Cyber Resilience Act, and the EU AI Act.

The project draws the attention of researchers in AI, NLP, and cybersecurity students and scholars studying requirements engineering, standards analysis, or trustworthy AI who might need to expand further. Likewise, security engineers, architects and enthusiasts with great interest in working with IoT and AI-enabled systems, compliance, risk, and assurance

professionals. Product developers facing multi-standard and regulatory compliance challenges.

16 Limitations

To ensure a feasible, focused, and academically sound degree project, the following restrictions and boundaries will be applied for the project.

Standards and Regulatory Scope

The project is strictly limited to the security requirements defined in: ETSI EN 303 645 (Consumer IoT Security) ETSI EN 304 223 (AI System Security) Other standards and regulations (e.g., ISO/IEC 27001, NIST frameworks, EU AI Act, Cyber Resilience Act) are not analysed or mapped, except for brief contextual references in the background section. The project does not attempt to create a unified or harmonized standard, only to map and compare existing requirements.

Technical Scope of Automation

The project focuses on automated or semi-automated mapping of textual security requirements using NLP and AI techniques. It does not include the implementation of security controls, penetration testing, vulnerability analysis, or validation of actual IoT or AI systems. The output of the system is decision support for human experts, not a legally binding or fully autonomous compliance assessment tool.

AI and NLP Methodology Limitations

The project evaluates a limited set of NLP approaches, such as: Rule-based NLP methods Transformer-based semantic similarity models Large Language Models (LLMs) used for comparison and analysis It does not involve training large models from scratch, due to computational and time constraints.

Only publicly available standard documents and derived annotations are used. The project does not include proprietary company data, internal policies, or confidential compliance documentation. By excluding legal decision-making, system implementation, and broader regulatory coverage, the project maintains a clear research focus aligned with the timeframe and objectives of an academic degree project.

17 Resources

The resources expected to be needed for the degree project on "Automated Compliance Mapping for IoT and AI Security Standards: An NLP-Based Approach" primarily consist of software tools and computational hardware:

Software Resources

Operating System: Linux-based environments (e.g., Ubuntu) are typically required for compatibility with most data science and NLP libraries.

For Compliance Mapping

IONI / Regology: Specialized AI for regulatory intelligence, mapping, and gap analysis.

Compliance.ai: Focuses on regulatory change management with expert-in-the-loop (EITL) ML.

Drata / Vanta: AI-powered automated evidence collection and framework mapping (SOC 2, ISO 27001).

Hyperproof: Uses hybrid AI for control mapping and audit readiness.

Holistic AI / FairNow: Specialized in AI risk management, bias monitoring, and regulatory compliance (EU AI Act).

LLM APIs & Frameworks: OpenAI (GPT-4o), Anthropic (Claude 3.5 Sonnet): Used for advanced reasoning in custom applications.

Libraries for NLP/Semantic Search: Spacy: Used for building custom Rule-based and NLP pipelines.

Sentence-Transformers (BERT-based): For creating semantic embeddings to compare policy text.

Hardware Resources

Standard Workstation: A modern laptop or desktop computer is sufficient for basic development, coding, and document writing.

High-Performance Computing (HPC): Access to substantial computational power is crucial for training large language models or deep learning systems.

Storage: Ample storage space (e.g. SSD) for large datasets, models, and project outputs.

Data and Information Resources

Standards Documents: Access to the official publications of ETSI EN 303 645 and ETSI EN 304 223.

Academic Resources: Access to university library resources (databases, journals) for literature reviews and related research papers. Online access to IEEE, Scopus, Researchgate.

If Project Extend to Test Repositories then,

Programming Languages: Python (most common for NLP/AI) is essential, along with key libraries: NLP Frameworks: Libraries such as spaCy, NLTK, or Hugging Face Transformers for text parsing, entity recognition, and semantic analysis.

Machine Learning/Deep Learning Frameworks: PyTorch or TensorFlow for building, training, and deploying NLP models (e.g., Transformer models). If required

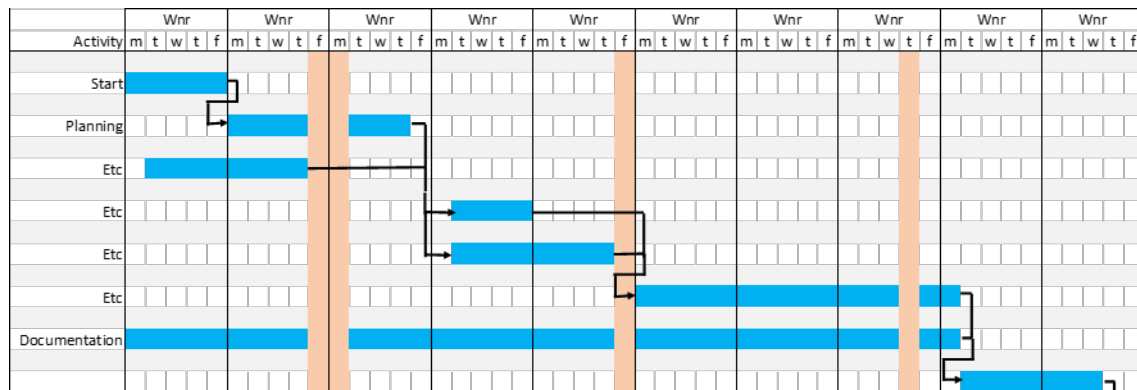
Data Handling: Pandas and NumPy for data manipulation and analysis.

Development Environment: An Integrated Development Environment (IDE) like VS Code or PyCharm, and version control software like Git and hosting services like GitHub or GitLab.

Database/Knowledge Graph Tools: Software like Neo4j (graph database) or traditional SQL databases (PostgreSQL, MySQL) might be needed to store and manage the structured knowledge graph of compliance requirements.

18 Schedule and activity plan

The schedule should show the order in which different activities are planned to be performed, including the scope of each activity and when in time they are to be performed (calendar week number or date). Following is the just the planned ghant chart but the scheduled task can be varies or can be changed with the timeline meeting with supervisor and major changes will be implemented as per the meeting objectives and feedback.



Weeks 1–2 (Feb)

Project planning & literature review

Reviewing the core academic literature on NLP-based semantic similarity, compliance mapping, and requirements analysis. Finalize scope and varifying methodology with supervisor.

Weeks 3–4 (Feb)

Standards analysis & requirement extraction

Analyze and understanding of ETSI EN 303 645 and ETSI EN 304 223. Selecting and extracting a subset of relevant security requirements. Preprocessing textual data for analysis.

Weeks 5–6 (Mar)

Manual mapping

Perform manual mapping of selected requirements to establish a baseline, categorizing relationships such as equivalence, overlap, or no relation.

Weeks 7–8 (Mar)

Rule-based NLP implementation

Implement rule-based approaches using keywords matching and domain-specific security terminology. Generate initial automated mapping results.

Weeks 9–10 (Apr)

Embedding-based semantic similarity

Apply transformer-based sentence embedding models (e.g., Sentence-BERT) to compute semantic similarity between requirements and generate candidate mappings.

		Use GPT with structured prompts to perform requirement comparison and mapping. evaluating output consistency and interpretability.
Weeks 11–12 (Apr)	LLM-based mapping experiments	
		Evaluate automatic approaches against the manual baseline using accuracy, coverage, efficiency, and interpretability metrics. Conduct qualitative error analysis.
Weeks 13–14 (Apr)	Evaluation & comparative analysis	
		Write results, discussion, limitations, and evaluation sections. Refine analysis and align findings with research questions.
Weeks 15–16 (May)	Thesis writing (results & discussion)	
		Complete introduction, background, methodology, and conclusion. Perform proofreading, formatting, supervisor feedback integration, and final submission.
Weeks 17–18 (May)	Final writing & submission	